Claude Code の Dev Container で低減できるリスク

（氏名）

2026 年 10 月 4 日

この資料の目的

Dev Container が 10 のリスクをどこまで低減するかを確かめる

10 のリスクは OWASP がまとめたものである [1]

OWASP

ソフトウェアの安全に
取り組む非営利団体

AI エージェントの
10 大リスク（2026 年版）

- ASI01 目標の乗っ取り
- ASI02 ツールの悪用
- ASI03 身元と権限の悪用
- ほか 7 つ（ASI04 ～ ASI10）

Dev Container は 4 つの管理策を備える [2]

Claude Code の Dev Container

Anthropic が公開する
開発用コンテナの設定例

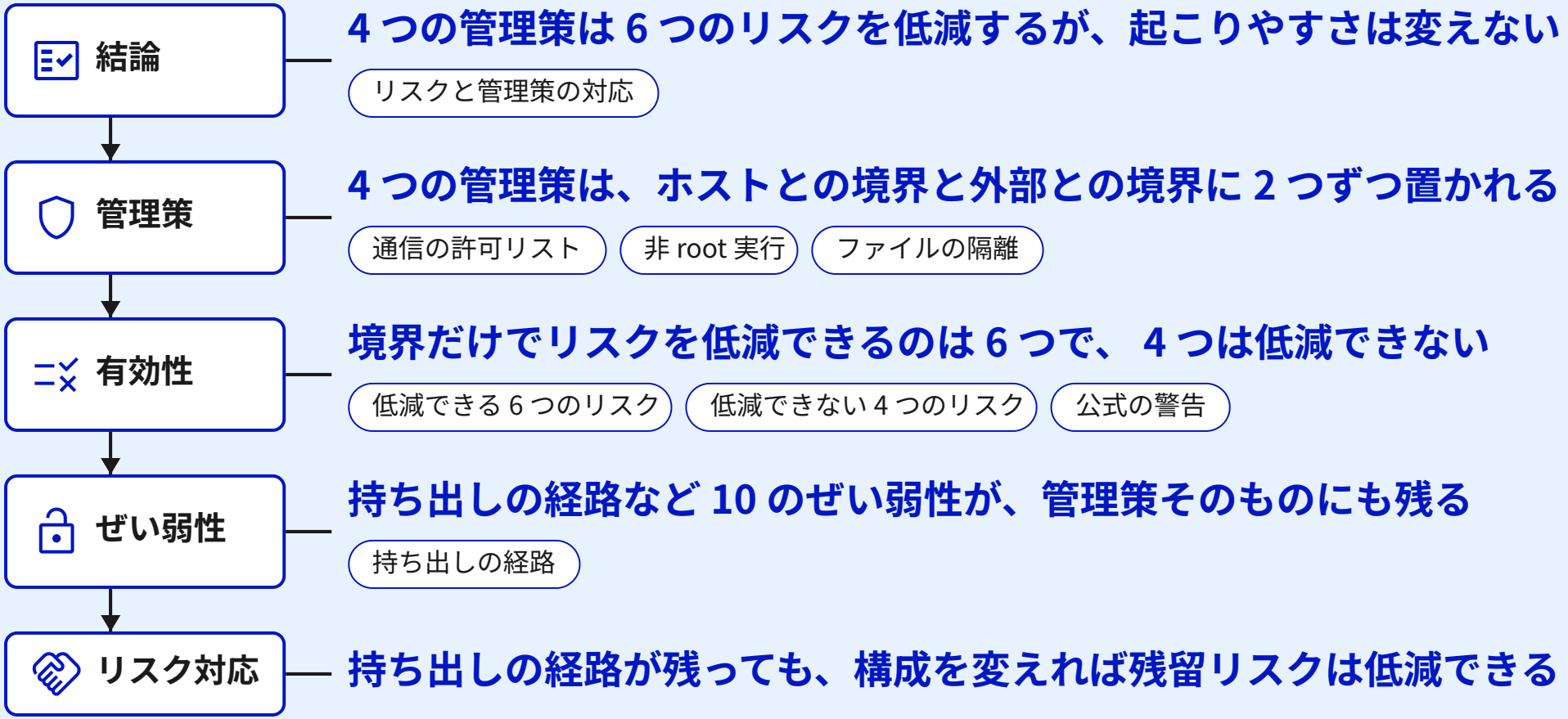
3 つの設定ファイルを読む

実機では検証していない

- 通信の許可リスト
- 非 root 実行
- ファイルの隔離
- 起動時の検証

まとめ

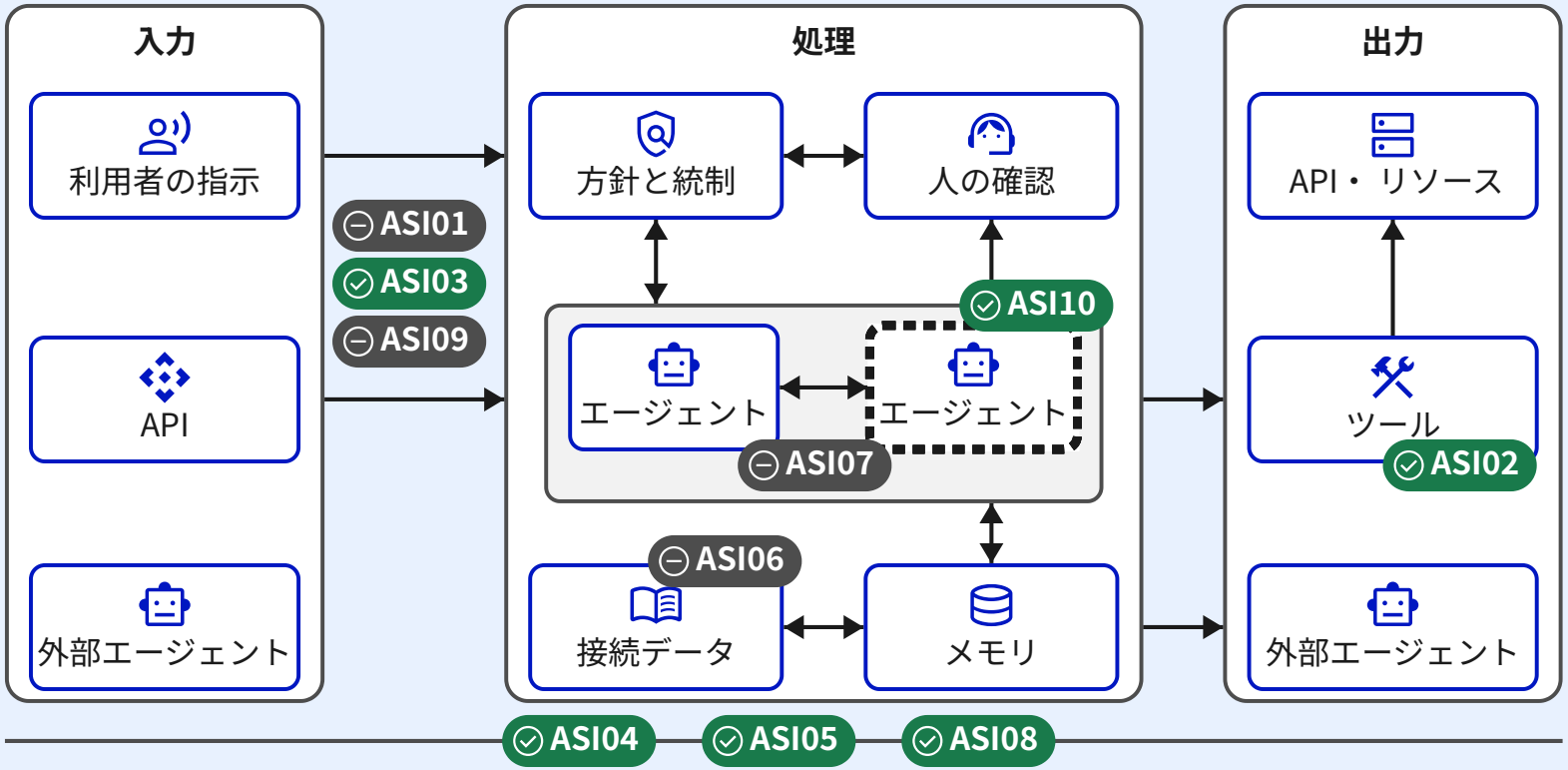
10 のリスクは、 4 つの管理策に追加のリスク対応を重ねれば低減できる



10 のリスクと管理策の有効性

4 つの管理策は 6 つのリスクを低減するが、起こりやすさは変えない

低減できないリスクは入力と処理の側に集まる



ASI01	目標の乗っ取り	⊖ 低減できない
ASI02	ツールの悪用	✓ 低減できる
ASI03	身元と権限の悪用	✓ 低減できる
ASI04	供給網のぜい弱性	✓ 低減できる
ASI05	想定外のコード実行	✓ 低減できる
ASI06	記憶と文脈の汚染	⊖ 低減できない
ASI07	安全でないエージェント間通信	⊖ 低減できない
ASI08	連鎖的な障害	✓ 低減できる
ASI09	人の信頼の悪用	⊖ 低減できない
ASI10	暴走エージェント	✓ 低減できる

リスクと管理策の対応

6 つのリスクには 4 つの管理策のどれかが効き、 4 つには効かない

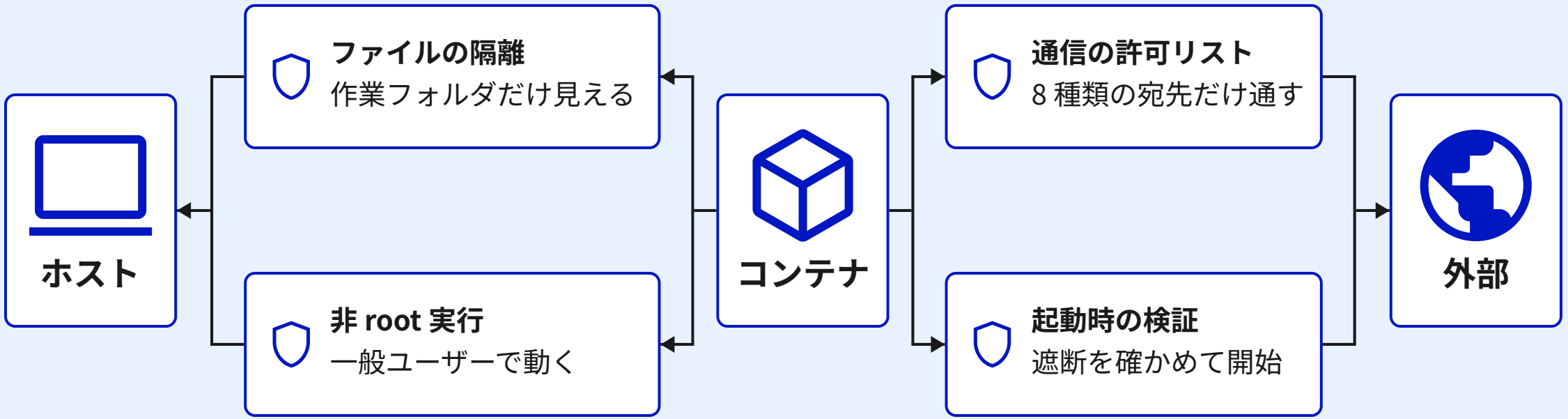
管理策が効く 6 つも、残留リスクが大きい構成では低減しきれない

リスク	どんなリスクか	通信の許可リスト	非 root 実行	ファイルの隔離	起動時の検証	残留リスクが大きい構成	有効性
ASI01 目標の乗っ取り	指示で目的が書き換わる					他人の文書を読む	⊖ 低減できない
ASI02 ツールの悪用	ツールが危険に使われる	✓		✓	✓	秘密や大事なデータを置く	⊘ 低減できる
ASI03 身元と権限の悪用	権限が範囲外で使われる		✓	✓		認証を引き継ぐ	⊘ 低減できる
ASI04 供給網のぜい弱性	取り込む部品が改ざん済み	✓			✓	外部の部品を取り込む	⊘ 低減できる
ASI05 想定外のコード実行	意図しない命令が動く	✓	✓	✓	✓	成果物をホストで動かす	⊘ 低減できる
ASI06 記憶と文脈の汚染	記憶に悪い情報が残る					履歴を引き継ぐ	⊖ 低減できない
ASI07 安全でないエージェント間通信	通信の相手が偽装される					複数を連携させる	⊖ 低減できない
ASI08 連鎖的な障害	1 つの誤りが他へ広がる		✓	✓		自動で後工程に流す	⊘ 低減できる
ASI09 人の信頼の悪用	人が出力を信じすぎる					確かめずに承認する	⊖ 低減できない
ASI10 暴走エージェント	役割から外れて動く	✓	✓	✓	✓	無人で動かす	⊘ 低減できる

4 つの管理策の配置

4 つの管理策は、ホストとの境界と外部との境界に 2 つずつ置かれる

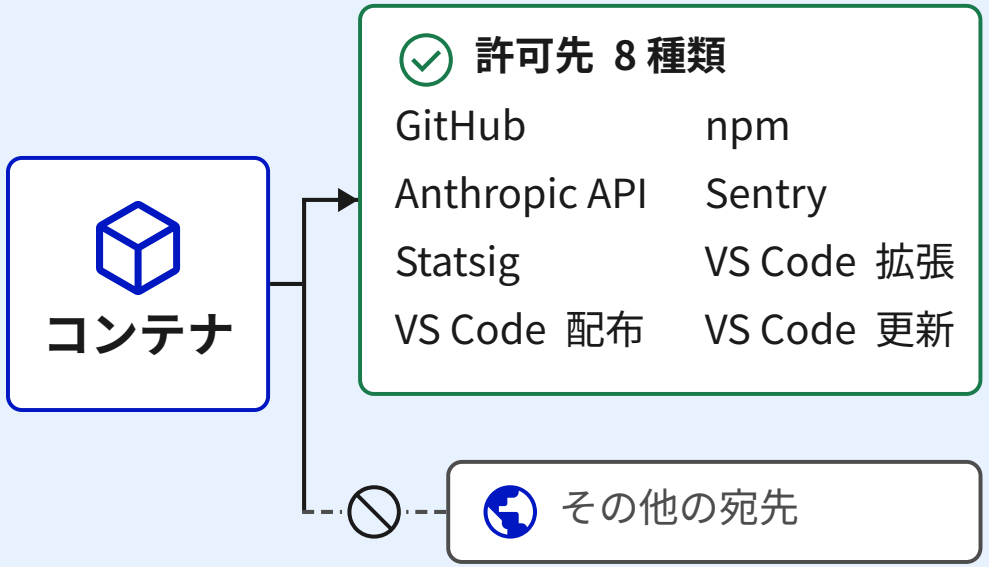
管理策は 3 つの領域の境界で働く



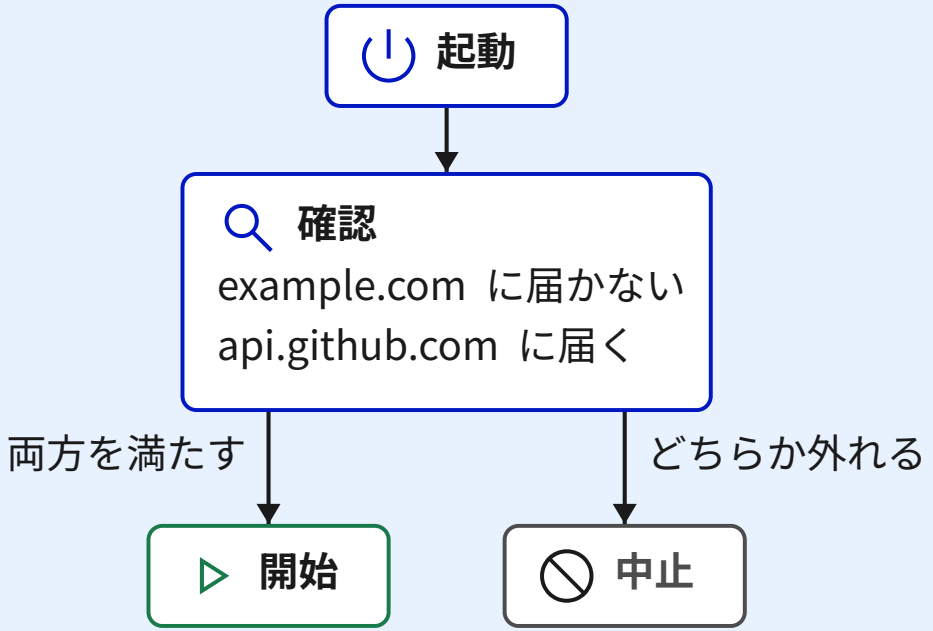
通信の許可リスト

外部との境界では、通信を許可リストにある宛先だけに絞る

外向きの通信は既定ですべて遮断される



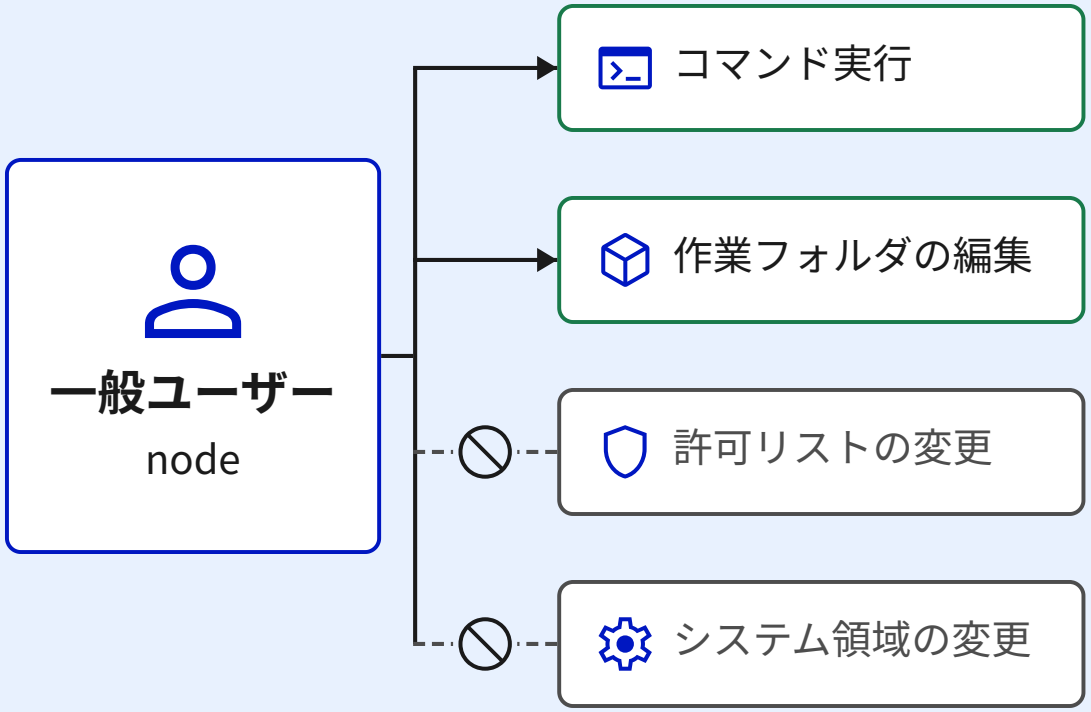
遮断は起動時に確かめられる



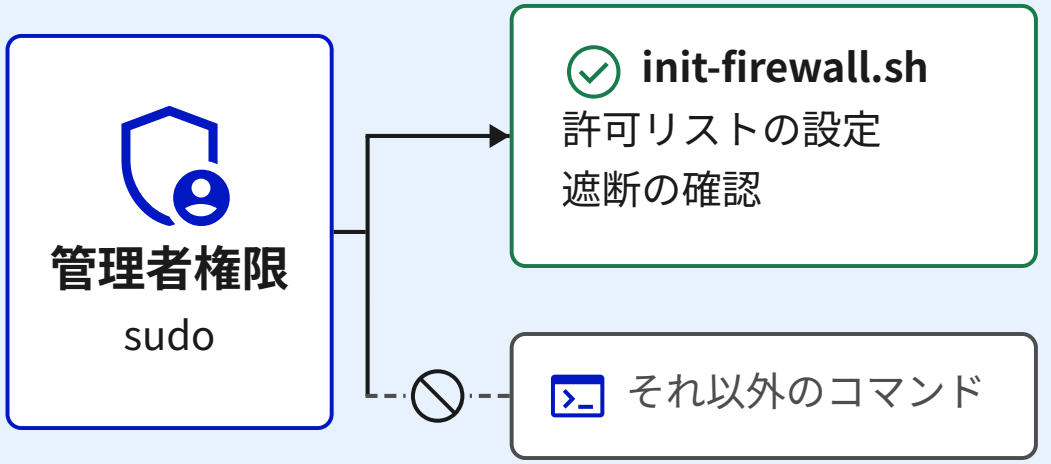
非 root 実行

許可リストは、一般ユーザーで動かすので書き換えられない

実行は一般ユーザーに限られる



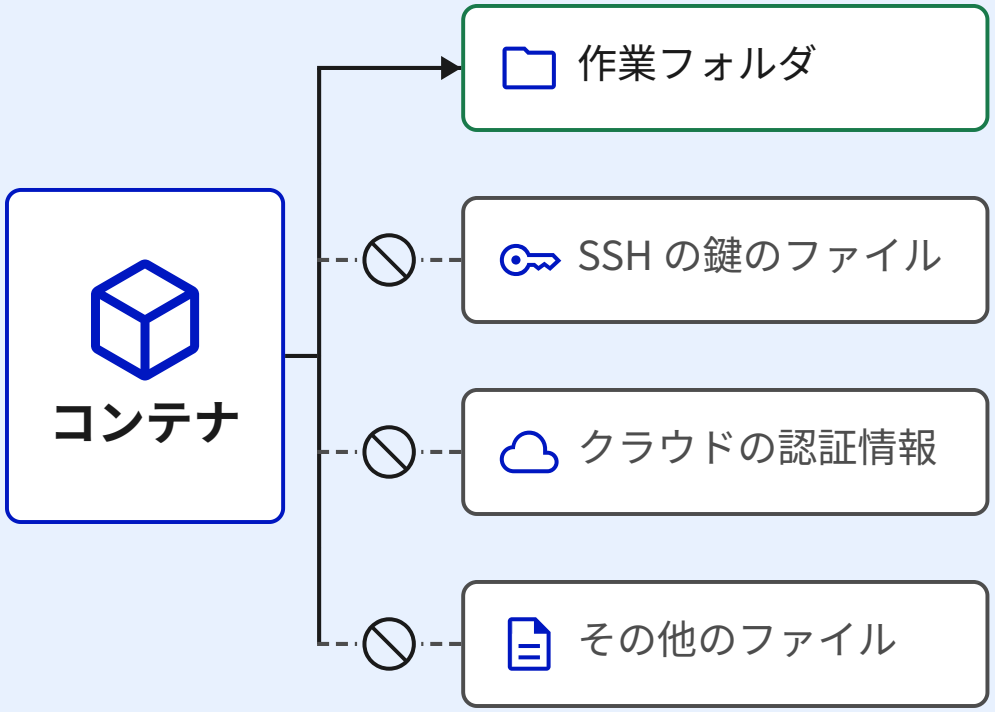
管理者権限は初期化にしか使えない



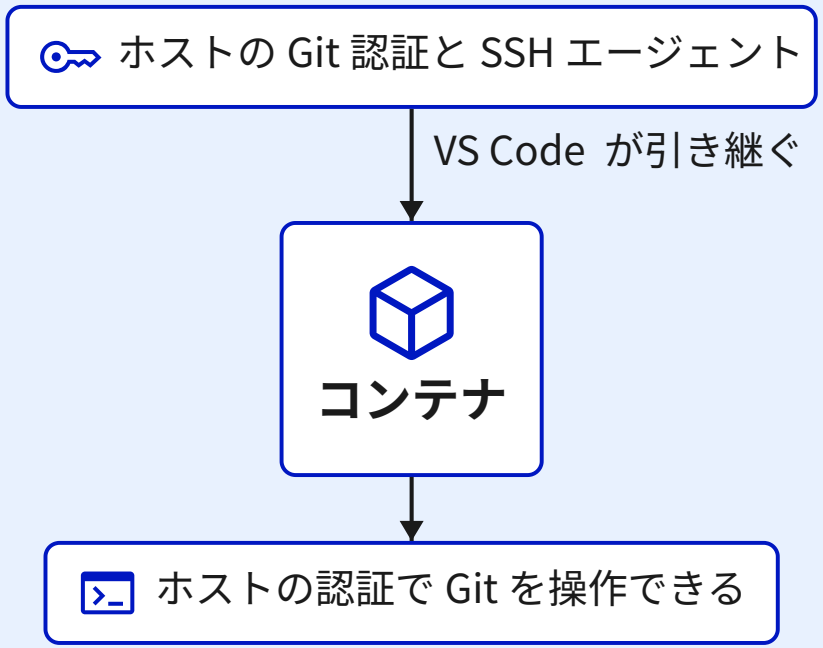
ファイルの隔離

一般ユーザーには、ホストとの境界で作業フォルダだけを見せる

ホストから渡すのは作業フォルダだけである



鍵は見えないがホストの認証は使える [3]



有効性の内訳

境界だけでリスクを低減できるのは 6 つで、 4 つは低減できない

どのリスクにも残留リスクが大きい構成が 1 つずつある

低減できる 6 つ

- **ASI02 ツールの悪用**
  秘密や大事なデータを置く
- **ASI03 身元と権限の悪用**
  認証を引き継ぐ
- **ASI04 供給網のぜい弱性**
  外部の部品を取り込む
- **ASI05 想定外のコード実行**
  成果物をホストで動かす
- **ASI08 連鎖的な障害**
  自動で後工程に流す
- **ASI10 暴走エージェント**
  無人で動かす

低減できない 4 つ

- **ASI01 目標の乗っ取り**
  他人の文書を読む
- **ASI06 記憶と文脈の汚染**
  履歴を引き継ぐ
- **ASI07 安全でないエージェント間通信**
  複数を連携させる
- **ASI09 人の信頼の悪用**
  確かめずに承認する

低減できる 6 つのリスク

低減できる 6 つも、コンテナの中にあるものは守れない

6 つのうち 2 つは、 VS Code でそのまま使うと当てはまる

リスク	管理策の働き	残留リスクが大きい構成	そのまま使うと
ASI02 ツールの悪用	ホストと許可外には届かない	秘密や大事なデータを置く	当てはまらない
ASI03 身元と権限の悪用	鍵のファイルは見えない	認証を引き継ぐ	当てはまる
ASI04 供給網のぜい弱性	通信先は許可先だけ	外部の部品を取り込む	当てはまる
ASI05 想定外のコード実行	実行はコンテナ内に留まる	成果物をホストで動かす	当てはまらない
ASI08 連鎖的な障害	コンテナ内に留まる	自動で後工程に流す	当てはまらない
ASI10 暴走エージェント	行動範囲を封じ込める	無人で動かす	当てはまらない

低減できない 4 つのリスク

コンテナで囲っても、判断と過信に関わる 4 つは低減できない

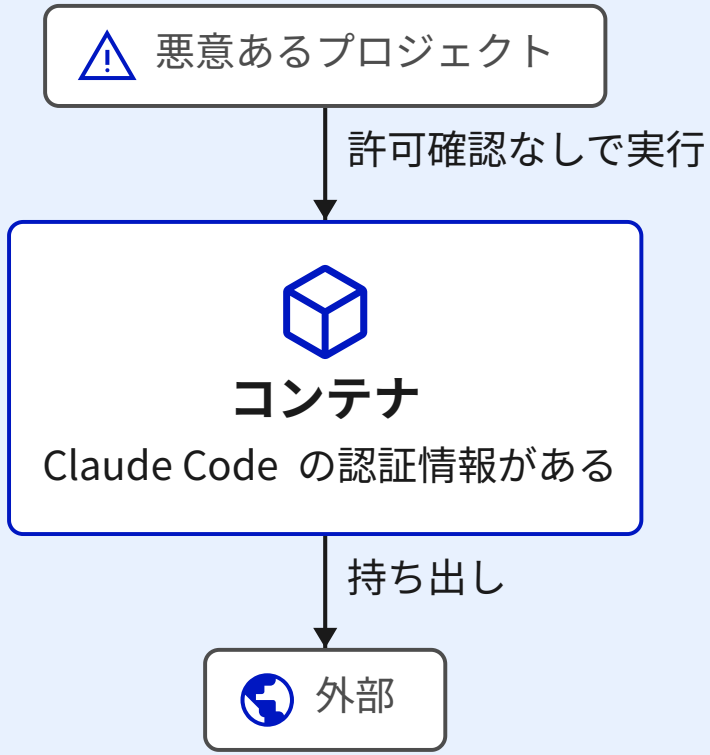
4 つとも隔離では止められず、 1 つだけが当てはまらない

リスク	管理策の働き	残留リスクが大きい構成	そのまま使うと
⊖ ASI01 目標の乗っ取り	読む内容を検査しない	他人の文書を読む	当てはまる
⊖ ASI06 記憶と文脈の汚染	保存内容を検査しない	履歴を引き継ぐ	当てはまる
⊖ ASI07 安全でないエージェント間通信	通信を守る仕組みがない	複数を連携させる	当てはまらない
⊖ ASI09 人の信頼の悪用	人の判断に関与しない	確かめずに承認する	当てはまる

公式の警告

過信せず認証情報の持ち出しに備えるよう、公式も警告している

許可確認を省くと持ち出しは防げない [4]



公式は使い方に 3 つの条件を付けている

- 信頼できるリポジトリで使う
- Claude の動作を監視する
- ホストの秘密を持ち込まない

管理策に残る 10 のぜい弱性

持ち出しの経路など 10 のぜい弱性が、管理策そのものにも残る

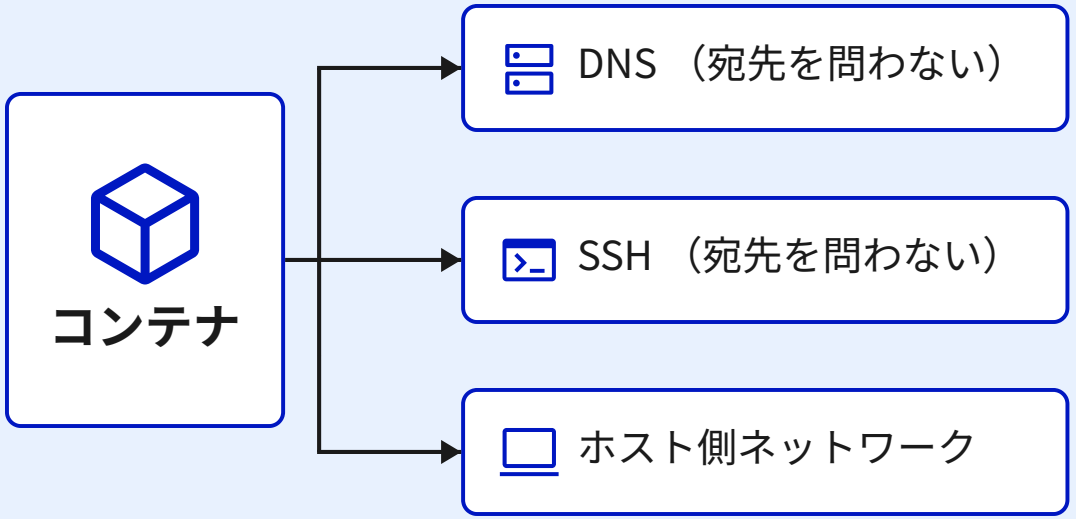
ぜい弱性は持ち出し、設定、波及、監視の 4 種類に分かれる

持ち出しの経路 4 つ	設定 3 つ	ホスト側への波及 2 つ	監視 1 つ
DNS の宛先が無制限	許可 IP が起動時に固定	作業フォルダ経由の実行	監視と記録がない
SSH の宛先が無制限	IPv6 の規則がない	ホストの認証の引き継ぎ	
許可先への送信	版が固定されていない		
ホスト側ネットワーク			

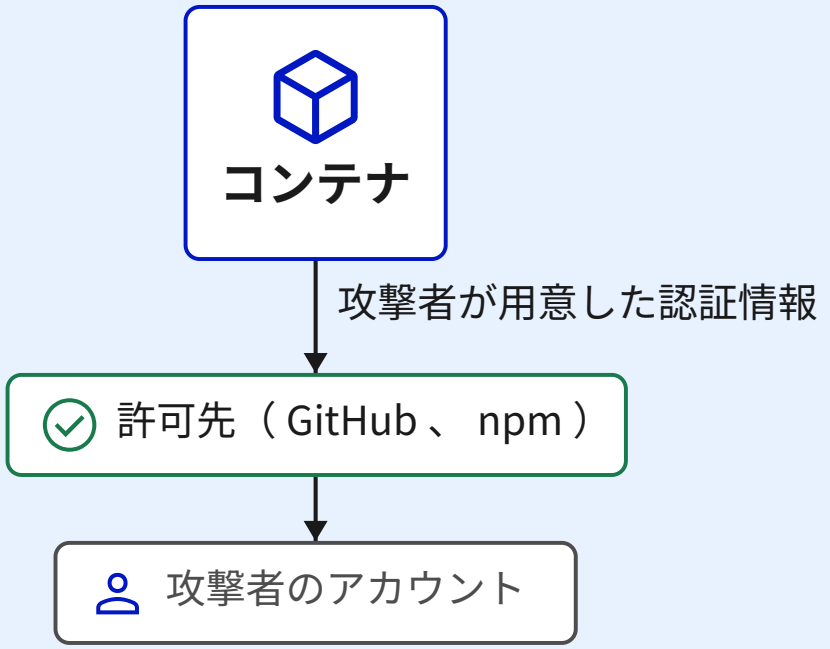
持ち出しの経路

ぜい弱性のうち持ち出しは、許可リストの例外と許可先そのものを通る

3 つの例外は許可リストを通らない



許可先へは攻撃者の認証情報で送れる



残留リスクへの対応

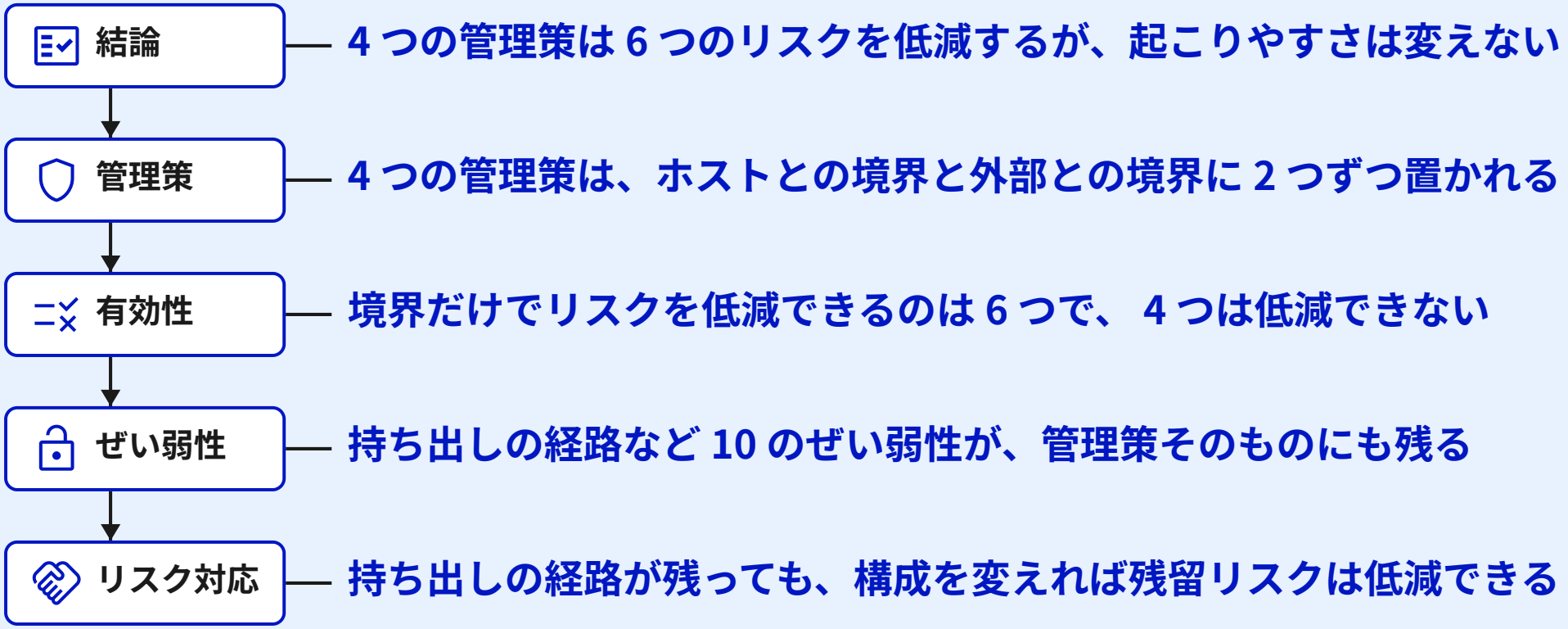
持ち出しの経路が残っても、構成を変えれば残留リスクは低減できる

どのリスクにも、残留リスクを低減する対応が 1 つずつある

リスク	残留リスクが大きい構成	リスク対応
ASI01 目標の乗っ取り	⃠ 他人の文書を読む	✓ 信頼できるリポジトリで使う
ASI02 ツールの悪用	⃠ 秘密や大事なデータを置く	✓ 秘密は絞り、データは控えを取る
ASI03 身元と権限の悪用	⃠ 認証を引き継ぐ	✓ 権限と期限を絞った認証だけ渡す
ASI04 供給網のぜい弱性	⃠ 外部の部品を取り込む	✓ 確かめた部品だけ取り込む
ASI05 想定外のコード実行	⃠ 成果物をホストで動かす	✓ 成果物はコンテナの中で動かす
ASI06 記憶と文脈の汚染	⃠ 履歴を引き継ぐ	✓ 履歴を持ち越さない
ASI07 安全でないエージェント間通信	⃠ 複数を連携させる	✓ 連携させない
ASI08 連鎖的な障害	⃠ 自動で後工程に流す	✓ 後工程に流す前に確かめる
ASI09 人の信頼の悪用	⃠ 確かめずに承認する	✓ 確かめてから承認する
ASI10 暴走エージェント	⃠ 無人で動かす	✓ 人が見ている間だけ動かす

まとめ

10 のリスクは、 4 つの管理策に追加のリスク対応を重ねれば低減できる



参考文献

1. OWASP Gen AI Security Project - Agentic Security Initiative,
"OWASP Top 10 for Agentic Applications for 2026" (2025);
genai.owasp.org/resource/owasp-top-10-for-agentic-applications-for-2026/
10 のリスクの図は、この文献の「 Agentic Top 10 At A Glance 」をもとに作成（ CC BY-SA 4.0 ）
2. Anthropic, claude-code: .devcontainer, commit 1c229fc (2026);
github.com/anthropics/claude-code/tree/main/.devcontainer
3. Microsoft, Sharing Git credentials with your container, Visual Studio Code Docs (2026);
code.visualstudio.com/remote/advancedcontainers/sharing-git-credentials
4. Anthropic, Development containers, Claude Code Docs (2026);
code.claude.com/docs/en/devcontainer